

7.15 Stack 08 — reconciled display and embedded-call audit

Identity and boundary

Reviewer: Codex, sole audit agent, 2026-09-27 UTC. Firmware predecessor is consolidated 7b PR #871 at 2483977523d9b6beab52a69429ace9aeefd00f76. Stack 08 code snapshot is aa16d06f7e8c2de434a257afb20de2118245cff3; the containing report commit and live CI/review outcome belong in the PR receipt. Python predecessor is #119 at 5c2dd4dbce5096de393b2db8c925f24950e22d8b; companion #120 head is d9a02d981ee43fe3e80b28ba02466670e6e8409d. All other dependency pins are unchanged. This is one code-bearing successor audit unit. Product branches are untouched.

The accepted predecessor already implements the 7.15 display and one-level embedded-call behavior. This unit completes source reconciliation, adds five adversarial wire contracts, requires them in the full-product report, and repairs the inherited local preflight failures. No firmware runtime, ABI, persistent storage, key derivation, trust source or Python production-library behavior changes. Four identical nanopb option declarations are removed; a parsed field/key/value comparison proves every effective bound is unchanged.

Historical Stack 08 commit dc8c80ec99a84b7f5381759ac03e041b2aadb92f changed 23 paths on an obsolete predecessor. Its advertised PR #838 base was not an ancestor. A replay on accepted 7b conflicted in 14 files. The attached reconciliation JSON accounts for every historical path and maps it to the current implementation, bounded replacement or documented deferral. The later owner decisions in HANDOFF-ERC7730-715-FORMATTERS.md and HANDOFF-ERC7730-PHASE-E.md control this audit's scope.

Current-source reconciliation

Historical behavior	Current disposition and evidence
Typed-data replay and binding	Current EIP-712 discovery/hash/replay preserves domain and signing path. Native CertifiedFieldReplayPreservesDomainAndSigningPath and TypedDataReplayBindsBothDomainAndMessageHashes; ordinary leaf and final typed-data confirmations remain.
ABI streams, array length and paths	Canonical nested ABI data validation retained. Display iteration is bounded to one calldata array, maximum 64 items; nested iterations and slices remain refused by shared capabilities and compiler. Current catalog/ABI tests and EX16/EX33 cover limits.
Groups, optional fields and conditions	Groups retain every field; optional condition opcode 3 always shows. Hiding/veto conditions, including membership and mustMatch, remain refused before review under the later 7.15 policy. EX39 and compiler/catalog tests cover the boundary.
Formatters, literals and intent	A-C implementation uses escaped text, device-owned titles, exact raw amounts alongside signer labels and multipart intent. Date, duration, unit and enum coverage retained. Signer metadata never supplies trusted token ticker/decimals.
Other formatter kinds	Kinds 9, 11, 12 and 14 remain outside the capability table as explicitly deferred in the 7.15 handoff. No historical full-spec claim is carried into acceptance.
Inner review and parent restoration	Current FETCH dispatch authenticates the envelope, binds decoded chain/callee/selector, freezes the parent's ID and resume point, preserves whole-transaction digests, and clears inner state when restoring the parent. New EX40-EX44 exercise these handlers.
Consent, signing and cleanup	Ordinary transaction/data-hash review remains additive. Cancellation produces Failure without signing; immediate retry uses ordinary review. Signature equality and altered-replay refusal are tested.
B08-001 embedded-NUL truncation	Superseded by 7b text escaping and EscapesStringCapturesAndRejectsSmallOutput: embedded NUL appears as a visible escape. Raw-formatter callers use bounded ABI captures or fixed 32-byte words; stream overflow is represented separately. No historical conflicting patch is replayed.

The source pass followed input through preload, capability validation, ABI capture, fetch/replay, confirmation, final signing and abort. Selection/replay requests bind the authenticated definition ID; fetch requests distinguish depth-one lookup from parent-ID

restoration. Inner BAD_PROGRAM/UNTRUSTED or an unsourced value follows the explicit 7.15 blind fallback after parent restoration. A mismatched chain/callee/selector or transport identity fails before the inner action. The parent cannot be replaced by another otherwise valid signed definition. The raw formatter's unchecked length is not reachable from an oversized external capture: its callers enforce the capture bound or construct a 32-byte word.

New contracts and counterexamples

Report ID	Contract
EX40	A 1,200-byte inner memo crosses transport replies at 1,024 and 31 bytes. Actual chunk counts/bounds, inner amount and ordinary signature equality are asserted. A modified inner memo on validation pass 5 fails before any inner field.
EX41	Changing only the outer operation word on inner validation pass 5 fails. This proves the digest covers bytes outside the inner call.
EX42	A separately accepted, correctly signed definition for the same outer selector is substituted after inner review. Parent-ID restoration refuses it before final signing. Eleven OLED frames show outer provenance/context and the reviewed inner recipient/amount.
EX43	Changing the inner definition ID after a 31-byte first chunk is refused before any inner action.
EX44	Declining Inner signer, Inner action or Inner field returns ActionCancelled. Retrying immediately without Initialize, signer reload or new preload yields an ordinary signature with zero definition requests and no certified screens.

All 39 predecessor runtime test bodies are AST-identical; five tests are added. The shared walker now counts a calldata pass only when offset is zero, verifies requested length against remaining bytes, and returns bounded chunks. Existing one-reply behavior survives the full suite. Python production `keepkeylib`, `firmware lib`, `firmware headers` and native tests are unchanged. Removing a predecessor test makes the preservation alarm fail.

Negative controls disable each new outer-byte/substitution/ID/cancellation injection; each affected test fails rather than silently accepting its fixture. Ignoring the 31-byte bound fails EX40 at $1024 > 31$. The earlier Stack 08 intake's production replay-digest bypass control remains applicable to the unchanged implementation. Report-validator controls reject each missing/skipped/failed EX40–EX44 full-product result while accepting expected Bitcoin-only skips. Contract-JUnit controls reject removed files, missing cases, wrong variant statuses, failures and duplicates.

Preflight repair

The inherited gate failed on duplicate Osmosis/Solana options, a missing report-gate test, and a read-only cppcheck cache path. The option duplicates are identical and their removal preserves all effective bounds. `scripts/test_generate_test_report.py` now exercises the actual dedicated-contract gate with valid and corrupted full/BTC evidence; CI invokes it before builds. The canonical preflight is brought into the branch. Its cppcheck cache has a writable temporary mount, and its argument extraction removes the CI shell return-code trailer. It uses Ubuntu 24.04 cppcheck and the same analysis flags as CI. The initial broken mount/argument run failed closed; these failures are retained in the local evidence. The matching code/pin preflight passed all Stage-1 mirrors before publishing Python #120; final firmware preflight is repeated after report/provenance edits. No inherited exception is carried forward.

Report-gate completion findings

The first preflight repair supplied tests for the current dedicated-contract validator but did not restore all six historical waiver/name-matching checks. A final equivalence check caught that omission before readiness. Restoring those tests against the first candidate produced one failure and five errors. B08-002: environment/JUnit capability declarations could bypass the checkout's waiver ledger. B08-003: a test name with an unrelated character prefix could satisfy a required suffix. The report generator now reads exactly one CI waiver ledger, rejects undeclared waivers, and matches only exact names or a module prefix ending in a dot. The historical six checks are retained alongside the three dedicated-contract checks and an additional environment-waiver check; capability-test environment is isolated so CI's real global ledger does not contaminate fixtures. All ten pass both with and without CI's staged environment.

The preceding head `aca549bb6d446e0a7f1bf66cf3c6f774d42d023f` passed every required job in CI 36299521967. Its verified report binds both PRs/SHAs and the run, records 1,497 passes and 89 skips with zero failures/errors, and includes both ARM variants. All five new runtime cases pass on full; all five skip on Bitcoin-only for the expected full-feature requirement. The

corrected report gate independently accepts all 1,586 actual JUnit cases. The subsequent changes affect only the report gate, its tests and receipts; firmware runtime and Python pin remain identical. Final-head CI and report identity are still required in the live receipt. The full ARM artifact has 17,800 bytes of SRAM reserve, above the 16,384-byte floor; both ARM manifests and every artifact size/digest were checked, with wrong-pin/digest controls rejected.

Copilot finding and immutable waiver authority

Python #120 passed review 5329239805 at d9a02d981ee43fe3e80b28ba02466670e6e8409d, with no inline/body findings or unresolved threads. Firmware review 5329251034 at 5037e7f24cd68f11a1815be7a77a2aeae06022d7 found B08-004: comparing waivers only with the candidate checkout proves self-consistency, not prior owner approval. The gate now compares that candidate ledger with `.github/workflows/ci.yml` from immutable, owner-accepted 7b commit 2483977523d9b6beab52a69429ace9aeefd00f76. Candidate removals are allowed; additions and unavailable authority fail closed. The two CI jobs consuming the gate fetch history to include this authority. Any future authority change requires separate review; this gate cannot defend against an attacker replacing the entire validation program or CI workflow, which remain code-review surfaces.

Four new regressions cover candidate expansion, narrowing, missing authority and immutable source selection. All 14 report-gate tests pass with clean and CI-like environments. A negative baseline proves the reviewed predecessor accepted an injected unapproved ledger entry; the fix rejects it while still accepting all 1,586 actual CI cases. The review body also names generic preflight correctness/portability/reproducibility concerns without a separate location or failing case. The sole concrete finding is B08-004; preflight is locally rerun before push, and exact-head CI remains authoritative for hosted execution.

Owner budget: at most three initial requests total across both repos, one breakdown into at most two units, then at most three requests per resulting unit; no recursive splits, stop for the night if exhausted. Two initial requests have been used (Python clean, firmware finding-bearing). Both reported Lite effort; Balanced was recommended but no setting was changed. This revised report precedes the third initial request. Live receipt records the actual reviewed head, request IDs, findings and CI result.

Verification at source freeze

Check	Result and provenance
Runtime and Stack07 wire contracts	65 passed, zero skipped, on the accepted 7b emulator with Stack 08 Python.
Compiler/catalog/protocol/report tests	39 passed, zero skipped; firmware validator and registry were mandatory. Registry pin 9f37816afde954ff6617fb5baa346133e5af26c5; 1,450 formats, 1,297 signable.
Native firmware	657 passed in fresh flash state, zero failures/skips; bundled JUnit. Unchanged firmware binary uses pinned image 7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2.
Report gate	Fourteen tests pass, with corrupted-input subcases; eight Python report tests pass, including the five new full/BTC controls.
OLED	EX42 passes and retains 11 hashed frames in one manifest; every frame visually inspected.
Preservation	All 39 earlier runtime method ASTs identical; no production firmware/Python-library or native-test changes. All 23 historical paths accounted for.
Options	Effective nanopb field/key/value maps equal before and after deletion.
Hosted qualification	Required on the final head: full/BTC ARM and emulator builds, native/integration, report, release-evidence and CI gates. Bind firmware/Python SHAs, both PR URLs, run URL and PDF hash before acceptance.

Initial local attempts are retained honestly: screenshot collection rejected a missing exact-selection environment variable; the Stack07 guard rejected an unspecified product variant; a native run collided with the live emulator's UDP port, and a reused native flash directory produced one recovery-initialization failure. Corrected invocations declare the product, select the capture method, stop the emulator during native execution and use fresh flash state. These are infrastructure/setup corrections; no assertion or firmware behavior was weakened.

Scope limits and review checkpoint

The accepted 7.15 policy keeps missing/unsupported inner definitions behind explicit blind warnings in AdvancedMode, bounded depth-one review, and refusal of unsupported nested iteration/slices. DELEGATECALL operation remains an outer descriptor field; the current inner review does not model execution storage context. The owner reserved that policy for 7.16. Typed embedded calls, deeper recursion and full-spec condition/metadata support are deferred. This audit does not represent those features as completed. Physical-device verification, assembled release acceptance, human review and promotion/publication remain release gates.

No new in-scope runtime defect was confirmed. The missing wire/evidence controls and broken local gate are repaired, including the report-validation gaps and immutable-authority finding above. The bounded external checkpoint can assess the new test walker, adversarial fixtures, report requirements and gate repairs; it cannot re-review predecessor implementation from this adjacent diff. Two registered initial requests at this source freeze; the explicit owner budget above controls subsequent requests. Current review/CI identities and outcomes are recorded in the PR receipt after delivery.

Complete adjacent inventory

The final report commit includes this source, its rendered PDF, reconciliation JSON and raw local evidence. The following table is generated from Git and rechecked after freezing. Python companion inventory is three paths: runtime test module, report generator and report-validator tests.

Added	Deleted	Path
8	1	.github/workflows/ci.yml
1	1	deps/python-keepkey
97	0	docs/release/audit-units/715-08-audit-20260927.md
-	-	docs/release/audit-units/715-08-audit-20260927.pdf
-	-	docs/release/audit-units/715-08-local-evidence-20260927.tgz
138	0	docs/release/audit-units/715-08-reconciliation-20260927.json
0	1	include/keepkey/transport/messages-osmosis.options
0	4	include/keepkey/transport/messages-solana.options
47	2	scripts/generate-test-report.py
117	0	scripts/preflight.sh
177	0	scripts/test_generate_test_report.py